

HỌC VIỆN QUỐC PHÒNG
TẠP CHÍ NGHỆ THUẬT QUÂN SỰ VIỆT NAM
Journal of Vietnamese Military Art



HỒ SƠ NGHIỆM THU DỰ ÁN PHẦN MỀM
TẠP CHÍ ĐIỆN TỬ NGHỆ THUẬT QUÂN SỰ VIỆT NAM

TÀI LIỆU
PHƯƠNG ÁN AN TOÀN THÔNG TIN
Bảo đảm ATTT cho hệ thống

Mã hiệu tài liệu	NTQS-NT-04
Phiên bản	1.0
Cấp độ	Lưu hành nội bộ
Đơn vị chủ quản	Học viện Quốc phòng
Chủ đầu tư / Tòa soạn	Tạp chí Nghệ thuật Quân sự Việt Nam

HÀ NỘI, NĂM 2026

1. MỤC ĐÍCH VÀ PHẠM VI

Tài liệu trình bày phương án bảo đảm an toàn thông tin (ATTT) của phần mềm “Tạp chí điện tử Nghệ thuật Quân sự Việt Nam”, bao gồm các biện pháp kỹ thuật về xác thực, phân quyền, kiểm soát truy cập, kiểm toán, bảo vệ dữ liệu và tăng cường an ninh cho môi trường vận hành mạng nội bộ/cô lập.

Nguyên tắc cốt lõi: không tin tưởng giao diện để bảo vệ dữ liệu — mọi kiểm soát bảo mật được thực thi ở backend.

2. XÁC THỰC VÀ PHIÊN LÀM VIỆC

Thành phần	Thiết kế
Đăng nhập	Email/mật khẩu; mật khẩu băm bcrypt (12 vòng)
Phiên đăng nhập	JWT: access token (8 giờ), refresh token (7 ngày), bí mật riêng cho refresh
Xác thực 2 lớp	TOTP (otplib, dung sai ± 1 bước thời gian) và Email OTP qua token tiên-xác thực (TTL 10 phút)
Mã dự phòng 2FA	10 mã, lưu dạng băm SHA-256; khuyến nghị in và cất giữ an toàn
Quản lý phiên	Theo dõi phiên, vô hiệu hóa phiên, cảnh báo an ninh (SecurityAlert)

Đối với mạng cô lập, ưu tiên TOTP; cần đồng bộ thời gian máy chủ qua NTP nội bộ để bảo đảm độ chính xác của mã.

3. PHÂN QUYỀN VÀ KIỂM SOÁT TRUY CẬP

- RBAC 11 vai trò với thứ bậc rõ ràng; thực thi tại middleware và guard route ở backend.
- Ma trận quyền theo tài nguyên – hành động (Permission/RolePermission).
- Kiểm soát phạm vi dữ liệu (scope): biên tập viên chuyên mục chỉ thấy bản thảo được phân công; độc giả không thấy bài chưa xuất bản.
- Bảo vệ phản biện kín hai chiều: ẩn danh tính theo chế độ kín ở tầng dịch vụ.
- Quyền nhạy cảm (xuất bản, quản trị người dùng) giới hạn cho vai trò phù hợp.

4. BẢO VỆ TUYẾN VÀ DỮ LIỆU ĐẦU VÀO

4.1. Giới hạn tần suất (rate limit)

Áp dụng giới hạn tần suất phân tầng theo mức độ nhạy cảm của tuyến (dùng Redis hoặc bộ nhớ trong):

Tuyến	Giới hạn	Cửa sổ
Đăng nhập	5 lần	15 phút
2FA	5 lần	10 phút

Tuyến	Giới hạn	Cửa sổ
Quên mật khẩu	3 lần	1 giờ
Đăng ký	5 lần	1 giờ
Tải tệp	20 lần	1 giờ
Ghi dữ liệu chung (POST/PUT/PATCH/DELETE)	120 lần	1 phút

4.2. Kiểm tra tệp tải lên

- Danh sách trắng loại MIME (PDF, DOC/DOCX, XLS/XLSX, TXT, ảnh); từ chối tệp thực thi/mã kịch bản.
- Kiểm tra chữ ký nhị phân (magic byte) chống giả mạo loại tệp; giới hạn kích thước; từ chối tệp rỗng.
- Làm sạch tên tệp, chống path traversal; không tin tên tệp từ client.
- Tuyến tải lên có giới hạn tần suất; tệp phục vụ qua tuyến kiểm soát, không lộ đường dẫn trực tiếp.

4.3. Kiểm tra đầu vào

Mọi đầu vào được kiểm tra trước nghiệp vụ (ưu tiên schema Zod), bao gồm tham số phân trang/lọc/sắp xếp.

5. NHẬT KÝ KIỂM TOÁN

Hệ thống ghi nhật ký kiểm toán (AuditLog) cho các nhóm thao tác nhạy cảm, kèm ngữ cảnh: chủ thể, hành động, đối tượng, địa chỉ IP, tác nhân (user agent), thời điểm.

Nhóm sự kiện	Ví dụ
Xác thực	Đăng nhập thành công/thất bại, đăng xuất, token hết hạn/không hợp lệ
Phân quyền	Từ chối truy cập, từ chối quyền
Người dùng	Tạo/sửa/khóa/mở tài khoản, đổi mật khẩu, nâng quyền
Bản thảo & phản biện	Nộp bài, đổi trạng thái, phân công/nộp phản biện
Biên tập & xuất bản	Quyết định biên tập, xuất bản/thu hồi bài
Hệ thống & dữ liệu	Đổi cấu hình, banner/menu, xuất/nhập dữ liệu, truy cập tệp

Phân biệt nhật ký kiểm toán với nhật ký ứng dụng/lỗi; không ghi bí mật (mật khẩu thô, OTP, token) vào nhật ký.

6. TĂNG CƯỜNG AN NINH ỨNG DỤNG

Biện pháp	Thiết lập
Chính sách CSP	default-src 'self'; tự lưu font/JS, không phụ thuộc CDN ngoài (phù hợp mạng cô lập)
HSTS	Bật ở môi trường production

Biện pháp	Thiết lập
Chống dò MIME	X-Content-Type-Options: nosniff
Chống XSS	X-XSS-Protection; kiểm soát nội dung động
Referrer / Permissions	strict-origin-when-cross-origin; tắt camera/micro/định vị

7. QUẢN LÝ BÍ MẬT VÀ CẤU HÌNH

- Không lưu cứng bí mật/credential trong mã nguồn; cấu hình qua biến môi trường.
- Bí mật (JWT_SECRET, khóa mã hóa ORCID, CRON_SECRET...) sinh tự động khi cài đặt.
- Không commit tệp .env vào kho mã nguồn.

8. BẢO VỆ DỮ LIỆU VÀ TÁCH BIỆT HỆ THỐNG

- Cơ sở dữ liệu tách biệt hoàn toàn, không dùng chung với hệ thống khác.
- Giữ lịch sử và ưu tiên xóa mềm với dữ liệu pháp lý/lịch sử; có chính sách lưu trữ.
- Bảo đảm nhất quán nhận diện NTQS; có kiểm thử chống lệch thương hiệu (branding-guard).

9. KHUYẾN NGHỊ TĂNG CƯỜNG (GIAI ĐOẠN SAU)

- Mã hóa dữ liệu khi lưu (at-rest) ở mức hệ điều hành/CSDL theo yêu cầu của đơn vị.
- Sao lưu định kỳ và quy trình khôi phục; diễn tập khôi phục.
- Giám sát bất thường đăng nhập theo IP; phát hiện thay đổi nhật ký kiểm toán.
- Bổ sung kiểm thử thâm nhập (pentest) trước khi mở rộng phạm vi truy cập.